

Exam : **CIPT**

Title : Certified Information Privacy
Technologist (CIPT)

Vendor : IAPP

Version : V13.35

NO.1 Which of the following statements is true regarding software notifications and agreements?

- (A). Website visitors must view the site's privacy statement before downloading software.
- (B). Software agreements are designed to be brief, while notifications provide more details.
- (C). It is a good practice to provide users with information about privacy prior to software installation.
- (D). "Just in time" software agreement notifications provide users with a final opportunity to modify the agreement.

Answer: C

NO.2 A credit card with the last few numbers visible is an example of what?

- (A). Masking data
- (B). Synthetic data
- (C). Sighting controls.
- (D). Partial encryption

Answer: A

NO.3 What is the main function of the Amnesic Incognito Live System or TAILS device?

- (A). It allows the user to run a self-contained computer from a USB device.
- (B). It accesses systems with a credential that leaves no discernable tracks.
- (C). It encrypts data stored on any computer on a network.
- (D). It causes a system to suspend its security protocols.

Answer: A

NO.4 In order to prevent others from identifying an individual within a data set, privacy engineers use a cryptographically-secure hashing algorithm. Use of hashes in this way illustrates the privacy tactic known as what?

- (A). Isolation.
- (B). Obfuscation.
- (C). Perturbation.
- (D). Stripping.

Answer: B

NO.5 SCENARIO

It should be the most secure location housing data in all of Europe, if not the world. The Global Finance Data Collective (GFDC) stores financial information and other types of client data from large banks, insurance companies, multinational corporations and governmental agencies. After a long climb on a mountain road that leads only to the facility, you arrive at the security booth. Your credentials are checked and checked again by the guard to visually verify that you are the person pictured on your passport and national identification card. You are led down a long corridor with server rooms on each side, secured by combination locks built into the doors. You climb a flight of stairs and are led into an office that is lighted brilliantly by skylights where the GFDC Director of Security, Dr. Monique Batch, greets you. On the far wall you notice a bank of video screens showing different rooms in the facility. At the far end, several screens show different sections of the road up the mountain Dr. Batch explains once again your mission. As a data security auditor and consultant, it is a dream assignment: The GFDC does not want simply adequate controls, but the best and most effective security that current technologies allow.

"We were hacked twice last year," Dr. Batch says, "and although only a small number of records were

stolen, the bad press impacted our business. Our clients count on us to provide security that is nothing short of impenetrable and to do so quietly. We hope to never make the news again." She notes that it is also essential that the facility is in compliance with all relevant security regulations and standards.

You have been asked to verify compliance as well as to evaluate all current security controls and security measures, including data encryption methods, authentication controls and the safest methods for transferring data into and out of the facility. As you prepare to begin your analysis, you find yourself considering an intriguing question: Can these people be sure that I am who I say I am? You are shown to the office made available to you and are provided with system login information, including the name of the wireless network and a wireless key. Still pondering, you attempt to pull up the facility's wireless network, but no networks appear in the wireless list. When you search for the wireless network by name, however it is readily found.

What type of wireless network does GFDC seem to employ?

- (A). A hidden network.
- (B). A reluctant network.
- (C). A user verified network.
- (D). A wireless mesh network.

Answer: A

NO.6 You are a wine collector who uses the web to do research about your hobby. You navigate to a news site and an ad for wine pops up. What kind of advertising is this?

- (A). Remnant.
- (B). Behavioral.
- (C). Contextual.
- (D). Demographic.

Answer: B

NO.7 A key principle of an effective privacy policy is that it should be?

- (A). Written in enough detail to cover the majority of likely scenarios.
- (B). Made general enough to maximize flexibility in its application.
- (C). Designed primarily by the organization's lawyers.
- (D). Presented with external parties as the intended audience.

Answer: D

NO.8 SCENARIO

Tom looked forward to starting his new position with a U.S.-based automobile leasing company (New Company), now operating in 32 states. New Company was recently formed through the merger of two prominent players, one from the eastern region (East Company) and one from the western region (West Company). Tom, a Certified Information Privacy Technologist (CIPT), is New Company's first Information Privacy and Security Officer. He met today with Dick from East Company, and Harry, from West Company. Dick and Harry are veteran senior information privacy and security professionals at their respective companies, and continue to lead the east and west divisions of New Company. The purpose of the meeting was to conduct a SWOT (strengths/weaknesses/opportunities/threats) analysis for New Company. Their SWOT analysis conclusions are summarized below.

Dick was enthusiastic about an opportunity for the New Company to reduce costs and increase

computing power and flexibility through cloud services. East Company had been contemplating moving to the cloud, but West Company already had a vendor that was providing it with software-as-a-service (SaaS). Dick was looking forward to extending this service to the eastern region. Harry noted that this was a threat as well, because West Company had to rely on the third party to protect its data.

Tom mentioned that neither of the legacy companies had sufficient data storage space to meet the projected growth of New Company, which he saw as a weakness. Tom stated that one of the team's first projects would be to construct a consolidated New Company data warehouse. Tom would personally lead this project and would be held accountable if information was modified during transmission to or during storage in the new data warehouse.

Tom, Dick and Harry agreed that employee network access could be considered both a strength and a weakness. East Company and West Company had strong performance records in this regard; both had robust network access controls that were working as designed. However, during a projected year-long transition period, New Company employees would need to be able to connect to a New Company network while retaining access to the East Company and West Company networks.

Which statement is correct about addressing New Company stakeholders' expectations for privacy?

- (A). New Company should expect consumers to read the company's privacy policy.
- (B). New Company should manage stakeholder expectations for privacy even when the stakeholders' data is not held by New Company.
- (C). New Company would best meet consumer expectations for privacy by adhering to legal requirements.
- (D). New Company's commitment to stakeholders ends when the stakeholders' data leaves New Company.

Answer: D

NO.9 What is a main benefit of data aggregation?

- (A). It is a good way to perform analysis without needing a statistician.
- (B). It applies two or more layers of protection to a single data record.
- (C). It allows one to draw valid conclusions from small data samples.
- (D). It is a good way to achieve de-identification and unlinkability.

Answer: C

NO.10 When should code audits be concluded?

- (A). At code check-in time.
- (B). At engineering design time.
- (C). While code is being sent to production.
- (D). Before launch after all code for a feature is complete.

Answer: D

NO.11 After committing to a Privacy by Design program, which activity should take place first?

- (A). Create a privacy standard that applies to all projects and services.
- (B). Establish a retention policy for all data being collected.
- (C). Implement easy to use privacy settings for users.
- (D). Perform privacy reviews on new projects.

Answer: B

NO.12 Which of the following is the least effective privacy preserving practice in the Systems Development Life Cycle (SDLC)?

- (A). Conducting privacy threat modeling for the use-case.
- (B). Following secure and privacy coding standards in the development.
- (C). Developing data flow modeling to identify sources and destinations of sensitive data.
- (D). Reviewing the code against Open Web Application Security Project (OWASP) Top 10 Security Risks.

Answer: C

NO.13 A user who owns a resource wants to give other individuals access to the resource. What control would apply?

- (A). Mandatory access control.
- (B). Role-based access controls.
- (C). Discretionary access control.
- (D). Context of authority controls.

Answer: B

NO.14 SCENARIO

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

First and last name
Date of birth (DOB)
Mailing address
Email address
Car VIN number
Car model
License plate
Insurance card number
Photo
Vehicle diagnostics
Geolocation

The app is designed to collect and transmit geolocation data. How can data collection best be limited to the necessary minimum?

- (A). Allow user to opt-out geolocation data collection at any time.
- (B). Allow access and sharing of geolocation data only after an accident occurs.
- (C). Present a clear and explicit explanation about need for the geolocation data.
- (D). Obtain consent and capture geolocation data at all times after consent is received.

Answer: D

NO.15 Which technique is most likely to facilitate the deletion of every instance of data associated with a deleted user account from every data store held by an organization?

- (A). Auditing the code which deletes user accounts.
- (B). Building a standardized and documented retention program for user data deletion.
- (C). Monitoring each data store for presence of data associated with the deleted user account.
- (D). Training engineering teams on the importance of deleting user accounts their associated data from all data stores when requested.

Answer: C

NO.16 A company configures their information system to have the following capabilities:

Allow for selective disclosure of attributes to certain parties, but not to others.

Permit the sharing of attribute references instead of attribute values - such as "I am over 21" instead of birthday date.

Allow for information to be altered or deleted as needed.

These capabilities help to achieve which privacy engineering objective?

- (A). Predictability.
- (B). Manageability.
- (C). Disassociability.
- (D). Integrity.

Answer: C

NO.17 SCENARIO

Carol was a U.S.-based glassmaker who sold her work at art festivals. She kept things simple by only accepting cash and personal checks.

As business grew, Carol couldn't keep up with demand, and traveling to festivals became burdensome. Carol opened a small boutique and hired Sam to run it while she worked in the studio. Sam was a natural salesperson, and business doubled. Carol told Sam, "I don't know what you are doing, but keep doing it!" But months later, the gift shop was in chaos. Carol realized that Sam needed help so she hired Jane, who had business expertise and could handle the back-office tasks. Sam would continue to focus on sales. Carol gave Jane a few weeks to get acquainted with the artisan craft business, and then scheduled a meeting for the three of them to discuss Jane's first impressions. At the meeting, Carol could not wait to hear Jane's thoughts, but she was unprepared for what Jane had to say. "Carol, I know that he doesn't realize it, but some of Sam's efforts to increase sales have put you in a vulnerable position. You are not protecting customers' personal information like you should." Sam said, "I am protecting our information. I keep it in the safe with our bank deposit. It's only a list of customers' names, addresses and phone numbers that I get from their checks before I deposit them. I contact them when you finish a piece that I think they would like. That's the only information I have! The only other thing I do is post photos and information about your work on the photo sharing site that I use with family and friends. I provide my email address and people send me their information if they want to see more of your work. Posting online really helps sales, Carol. In fact, the only complaint I hear is about having to come into the shop to make a purchase." Carol replied, "Jane, that doesn't sound so bad. Could you just fix things and help us to post even more online?"

"I can," said Jane. "But it's not quite that simple. I need to set up a new program to make sure that we follow the best practices in data management. And I am concerned for our customers. They should be able to manage how we use their personal information. We also should develop a social media strategy." Sam and Jane worked hard during the following year. One of the decisions they made was to contract with an outside vendor to manage online sales. At the end of the year, Carol shared some

exciting news. "Sam and Jane, you have done such a great job that one of the biggest names in the glass business wants to buy us out! And Jane, they want to talk to you about merging all of our customer and vendor information with theirs beforehand." When initially collecting personal information from customers, what should Jane be guided by?

- (A). Onward transfer rules.
- (B). Digital rights management.
- (C). Data minimization principles.
- (D). Vendor management principles

Answer: B

NO.18 SCENARIO

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

First and last name
Date of birth (DOB)
Mailing address
Email address
Car VIN number
Car model
License plate
Insurance card number
Photo
Vehicle diagnostics
Geolocation

All of the following technical measures can be implemented by EnsureClaim to protect personal information that is accessible by third-parties EXCEPT?

- (A). Encryption.
- (B). Access Controls.
- (C). De-identification.
- (D). Multi-factor authentication.

Answer: B

NO.19 Organizations understand there are aggregation risks associated with the way the process their customer's data. They typically include the details of this aggregation risk in a privacy notice and ask that all customers acknowledge they understand these risks and consent to the processing. What type of risk response does this notice and consent represent?

- (A). Risk transfer.
- (B). Risk mitigation.
- (C). Risk avoidance.
- (D). Risk acceptance.

Answer: A

NO.20 During a transport layer security (TLS) session, what happens immediately after the web browser creates a random PreMasterSecret?

- (A). The server decrypts the PremasterSecret.
- (B). The web browser opens a TLS connection to the PremasterSecret.
- (C). The web browser encrypts the PremasterSecret with the server's public key.
- (D). The server and client use the same algorithm to convert the PremasterSecret into an encryption key.

Answer: C

NO.21 SCENARIO

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

First and last name
Date of birth (DOB)
Mailing address
Email address
Car VIN number
Car model
License plate
Insurance card number
Photo
Vehicle diagnostics
Geolocation

What would be the best way to supervise the third-party systems the EnsureClaim App will share data with?

- (A). Review the privacy notices for each third-party that the app will share personal data with to determine adequate privacy and data protection controls are in place.
- (B). Conduct a security and privacy review before onboarding new vendors that collect personal data from the app.
- (C). Anonymize all personal data collected by the app before sharing any data with third-parties.
- (D). Develop policies and procedures that outline how data is shared with third-party apps.

Answer: C

NO.22 What term describes two re-identifiable data sets that both come from the same unidentified individual?

- (A). Pseudonymous data.
- (B). Anonymous data.
- (C). Aggregated data.
- (D). Imprecise data.

Answer: B

NO.23 How does k-anonymity help to protect privacy in micro data sets?

- (A). By ensuring that every record in a set is part of a group of "k" records having similar identifying information.
- (B). By switching values between records in order to preserve most statistics while still maintaining privacy.
- (C). By adding sufficient noise to the data in order to hide the impact of any one individual.
- (D). By top-coding all age data above a value of "k."

Answer: A

NO.24 SCENARIO

Carol was a U.S.-based glassmaker who sold her work at art festivals. She kept things simple by only accepting cash and personal checks.

As business grew, Carol couldn't keep up with demand, and traveling to festivals became burdensome. Carol opened a small boutique and hired Sam to run it while she worked in the studio. Sam was a natural salesperson, and business doubled. Carol told Sam, "I don't know what you are doing, but keep doing it!" But months later, the gift shop was in chaos. Carol realized that Sam needed help so she hired Jane, who had business expertise and could handle the back-office tasks. Sam would continue to focus on sales. Carol gave Jane a few weeks to get acquainted with the artisan craft business, and then scheduled a meeting for the three of them to discuss Jane's first impressions. At the meeting, Carol could not wait to hear Jane's thoughts, but she was unprepared for what Jane had to say. "Carol, I know that he doesn't realize it, but some of Sam's efforts to increase sales have put you in a vulnerable position. You are not protecting customers' personal information like you should." Sam said, "I am protecting our information. I keep it in the safe with our bank deposit. It's only a list of customers' names, addresses and phone numbers that I get from their checks before I deposit them. I contact them when you finish a piece that I think they would like. That's the only information I have! The only other thing I do is post photos and information about your work on the photo sharing site that I use with family and friends. I provide my email address and people send me their information if they want to see more of your work. Posting online really helps sales, Carol. In fact, the only complaint I hear is about having to come into the shop to make a purchase." Carol replied, "Jane, that doesn't sound so bad. Could you just fix things and help us to post even more online?"

"I can," said Jane. "But it's not quite that simple. I need to set up a new program to make sure that we follow the best practices in data management. And I am concerned for our customers. They should be able to manage how we use their personal information. We also should develop a social media strategy." Sam and Jane worked hard during the following year. One of the decisions they made was to contract with an outside vendor to manage online sales. At the end of the year, Carol shared some exciting news. "Sam and Jane, you have done such a great job that one of the biggest names in the glass business wants to buy us out! And Jane, they want to talk to you about merging all of our customer and vendor information with theirs beforehand." Which regulator has jurisdiction over the shop's data management practices?

- (A). The Federal Trade Commission.
- (B). The Department of Commerce.
- (C). The Data Protection Authority.
- (D). The Federal Communications Commission.

Answer: A

NO.25 What can be used to determine the type of data in storage without exposing its contents?

- (A). Collection records.
- (B). Data mapping.
- (C). Server logs.
- (D). Metadata.

Answer: D

NO.26 Which is NOT a suitable method for assuring the quality of data collected by a third-party company?

- (A). Verifying the accuracy of the data by contacting users.
- (B). Validating the company's data collection procedures.
- (C). Introducing erroneous data to see if its detected.
- (D). Tracking changes to data through auditing.

Answer: A

NO.27 Which of the following modes of interaction often target both people who personally know and are strangers to the attacker?

- (A). Spam.
- (B). Phishing.
- (C). Unsolicited sexual imagery.
- (D). Consensually-shared sexual imagery.

Answer: B

NO.28 Which of the following would be the most appropriate solution for preventing privacy violations related to information exposure through an error message?

- (A). Configuring the environment to use shorter error messages.
- (B). Handling exceptions internally and not displaying errors to the user.
- (C). Creating default error pages or error messages which do not include variable data.
- (D). Logging the session name and necessary parameters once the error occurs to enable trouble shooting.

Answer: C

NO.29 Under the Family Educational Rights and Privacy Act (FERPA), releasing personally identifiable information from a student's educational record requires written permission from the parent or eligible student in order for information to be?

- (A). Released to a prospective employer.
- (B). Released to schools to which a student is transferring.
- (C). Released to specific individuals for audit or evaluation purposes.
- (D). Released in response to a judicial order or lawfully ordered subpoena.

Answer: C

NO.30 SCENARIO

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource

database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clean-Q invited vendors to present potential solutions to their current operational issues. These vendors included Application developers and Cloud-Q's solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.

A resource facing web interface that enables resources to apply and manage their assigned jobs.

An online payment facility for customers to pay for services.

Which question would you most likely ask to gain more insight about LeadOps and provide practical privacy recommendations?

- (A). What is LeadOps' annual turnover?
- (B). How big is LeadOps' employee base?
- (C). Where are LeadOps' operations and hosting services located?
- (D). Does LeadOps practice agile development and maintenance of their system?

Answer: D

NO.31 What would be an example of an organization transferring the risks associated with a data breach?

- (A). Using a third-party service to process credit card transactions.
- (B). Encrypting sensitive personal data during collection and storage
- (C). Purchasing insurance to cover the organization in case of a breach.
- (D). Applying industry standard data handling practices to the organization's practices.

Answer: C

NO.32 Which of the following is NOT relevant to a user exercising their data portability rights?

- (A). Notice and consent for the downloading of data.

- (B). Detection of phishing attacks against the portability interface.
- (C). Re-authentication of an account, including two-factor authentication as appropriate.
- (D). Validation of users with unauthenticated identifiers (e.g. IP address, physical address).

Answer: D

NO.33 What must be done to destroy data stored on "write once read many" (WORM) media?

- (A). The data must be made inaccessible by encryption.
- (B). The erase function must be used to remove all data.
- (C). The media must be physically destroyed.
- (D). The media must be reformatted.

Answer: C

NO.34 Which is the most accurate type of biometrics?

- (A). DNA
- (B). Voiceprint.
- (C). Fingerprint.
- (D). Facial recognition.

Answer: B

NO.35 What tactic does pharming use to achieve its goal?

- (A). It modifies the user's Hosts file.
- (B). It encrypts files on a user's computer.
- (C). It creates a false display advertisement.
- (D). It generates a malicious instant message.

Answer: C

NO.36 A company seeking to hire engineers in Silicon Valley ran an ad campaign targeting women in a specific age range who live in the San Francisco Bay Area.

Which Calo objective privacy harm is likely to result from this campaign?

- (A). Lost opportunity.
- (B). Economic loss.
- (C). Loss of liberty.
- (D). Social detriment.

Answer: D

NO.37 SCENARIO

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file. Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered

owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine.

After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

What should Finley Motors have done to incorporate the transparency principle of Privacy by Design (PbD)?

- (A). Signed a data sharing agreement with AMP Payment Resources.
- (B). Documented that Finley Motors has a legitimate interest to share Chuck's information.
- (C). Obtained verbal consent from Chuck and recorded it within internal systems.
- (D). Provided notice of data sharing practices within the electronically signed rental agreement.

Answer: D

NO.38 What distinguishes a "smart" device?

- (A). It can perform multiple data functions simultaneously.
- (B). It is programmable by a user without specialized training.
- (C). It can reapply access controls stored in its internal memory.
- (D). It augments its intelligence with information from the internet.

Answer: D

NO.39 SCENARIO

Carol was a U.S.-based glassmaker who sold her work at art festivals. She kept things simple by only accepting cash and personal checks.

As business grew, Carol couldn't keep up with demand, and traveling to festivals became burdensome. Carol opened a small boutique and hired Sam to run it while she worked in the studio. Sam was a natural salesperson, and business doubled. Carol told Sam, "I don't know what you are doing, but keep doing it!" But months later, the gift shop was in chaos. Carol realized that Sam needed help so she hired Jane, who had business expertise and could handle the back-office tasks. Sam would continue to focus on sales. Carol gave Jane a few weeks to get acquainted with the artisan craft business, and then scheduled a meeting for the three of them to discuss Jane's first impressions. At the meeting, Carol could not wait to hear Jane's thoughts, but she was unprepared for what Jane had to say. "Carol, I know that he doesn't realize it, but some of Sam's efforts to increase sales have put you in a vulnerable position. You are not protecting customers' personal information like you should." Sam said, "I am protecting our information. I keep it in the safe with our bank deposit. It's only a list of customers' names, addresses and phone numbers that I get from their checks before I deposit them. I contact them when you finish a piece that I think they would like. That's the only information I have! The only other thing I do is post photos and information about your work on the photo sharing site that I use with family and friends. I provide my email address and people send me their information if they want to see more of your work. Posting online really helps sales, Carol. In fact, the only complaint I hear is about having to come into the shop to make a purchase." Carol replied, "Jane, that doesn't sound so bad. Could you just fix things and help us to post even more

online?"

"I can," said Jane. "But it's not quite that simple. I need to set up a new program to make sure that we follow the best practices in data management. And I am concerned for our customers. They should be able to manage how we use their personal information. We also should develop a social media strategy." Sam and Jane worked hard during the following year. One of the decisions they made was to contract with an outside vendor to manage online sales. At the end of the year, Carol shared some exciting news. "Sam and Jane, you have done such a great job that one of the biggest names in the glass business wants to buy us out! And Jane, they want to talk to you about merging all of our customer and vendor information with theirs beforehand." What type of principles would be the best guide for Jane's ideas regarding a new data management program?

- (A). Collection limitation principles.
- (B). Vendor management principles.
- (C). Incident preparedness principles.
- (D). Fair Information Practice Principles

Answer: D

NO.40 Not updating software for a system that processes human resources data with the latest security patches may create what?

- (A). Authentication issues.
- (B). Privacy vulnerabilities.
- (C). Privacy threat vectors.
- (D). Reportable privacy violations.

Answer: B

NO.41 What is the term for information provided to a social network by a member?

- (A). Profile data.
- (B). Declared data.
- (C). Personal choice data.
- (D). Identifier information.

Answer: A

NO.42 SCENARIO

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis. LBH also implements Privacy by Design (PbD) into the

application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

What is the best way to minimize the risk of an exposure violation through the use of the app?

- (A). Prevent the downloading of photos stored in the app.
- (B). Dissociate the patient health data from the personal data.
- (C). Exclude the collection of personal information from the health record.
- (D). Create a policy to prevent combining data with external data sources.

Answer: D

NO.43 SCENARIO

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

First and last name
Date of birth (DOB)
Mailing address
Email address
Car VIN number
Car model
License plate
Insurance card number
Photo
Vehicle diagnostics
Geolocation

What IT architecture would be most appropriate for this mobile platform?

- (A). Peer-to-peer architecture.
- (B). Client-server architecture.
- (C). Plug-in-based architecture.
- (D). Service-oriented architecture.

Answer: D

NO.44 Which activity would best support the principle of data quality?

- (A). Providing notice to the data subject regarding any change in the purpose for collecting such data.
- (B). Ensuring that the number of teams processing personal information is limited.
- (C). Delivering information in a format that the data subject understands.
- (D). Ensuring that information remains accurate.

Answer: D

NO.45 SCENARIO

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clean-Q invited vendors to present potential solutions to their current operational issues. These vendors included Application developers and Cloud-Q's solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.

A resource facing web interface that enables resources to apply and manage their assigned jobs.

An online payment facility for customers to pay for services.

What is a key consideration for assessing external service providers like LeadOps, which will conduct personal information processing operations on Clean-Q's behalf?

- (A). Understanding LeadOps' costing model.
- (B). Establishing a relationship with the Managing Director of LeadOps.
- (C). Recognizing the value of LeadOps' website holding a verified security certificate.
- (D). Obtaining knowledge of LeadOps' information handling practices and information security environment.

Answer: D

NO.46 SCENARIO

WebTracker Limited is a cloud-based online marketing service located in London. Last year, WebTracker migrated its IT infrastructure to the cloud provider Amazon, which provides SQL Databases and Artificial Intelligence services to WebTracker. The roles and responsibilities between the two companies have been formalized in a standard contract, which includes allocating the role of

data controller to WebTracker.

The CEO of WebTracker, Mr. Bond, would like to assess the effectiveness of AmaZure's privacy controls, and he recently decided to hire you as an independent auditor. The scope of the engagement is limited only to the marketing services provided by WebTracker, you will not be evaluating any internal data processing activity, such as HR or Payroll.

This ad-hoc audit was triggered due to a future partnership between WebTracker and SmartHome - a partnership that will not require any data sharing. SmartHome is based in the USA, and most recently has dedicated substantial resources to developing smart refrigerators that can suggest the recommended daily calorie intake based on DNA information. This and other personal data is collected by WebTracker.

To get an idea of the scope of work involved, you have decided to start reviewing the company's documentation and interviewing key staff to understand potential privacy risks.

The results of this initial work include the following notes:

There are several typos in the current privacy notice of WebTracker, and you were not able to find the privacy notice for SmartHome.

You were unable to identify all the sub-processors working for SmartHome. No subcontractor is indicated in the cloud agreement with AmaZure, which is responsible for the support and maintenance of the cloud infrastructure.

There are data flows representing personal data being collected from the internal employees of WebTracker, including an interface from the HR system.

Part of the DNA data collected by WebTracker was from employees, as this was a prototype approved by the CEO of WebTracker.

All the WebTracker and SmartHome customers are based in USA and Canada.

Which of the following issues is most likely to require an investigation by the Chief Privacy Officer (CPO) of WebTracker?

- (A). Data flows use encryption for data at rest, as defined by the IT manager.
- (B). AmaZure sends newsletter to WebTracker customers, as approved by the Marketing Manager.
- (C). Employees' personal data are being stored in a cloud HR system, as approved by the HR Manager.
- (D). File Integrity Monitoring is being deployed in SQL servers, as indicated by the IT Architect Manager.

Answer: B

NO.47 Which is NOT a suitable action to apply to data when the retention period ends?

- (A). Aggregation.
- (B). De-identification.
- (C). Deletion.
- (D). Retagging.

Answer: C

NO.48 What is the main benefit of using dummy data during software testing?

- (A). The data comes in a format convenient for testing.
- (B). Statistical disclosure controls are applied to the data.
- (C). The data enables the suppression of particular values in a set.
- (D). Developers do not need special privacy training to test the software.

Answer: D

NO.49 All of the following can be indications of a ransomware attack EXCEPT?

- (A). The inability to access certain files.
- (B). An increased amount of spam email in an individual's inbox.
- (C). An increase in activity of the CPU of a computer for no apparent reason.
- (D). The detection of suspicious network communications between the ransomware and the attacker's command and control servers.

Answer: B

NO.50 SCENARIO

Please use the following to answer the next question:

Jordan just joined a fitness-tracker start-up based in California, USA, as its first Information Privacy and Security Officer. The company is quickly growing its business but does not sell any of the fitness trackers itself. Instead, it relies on a distribution network of third-party retailers in all major countries. Despite not having any stores, the company has a 78% market share in the EU. It has a website presenting the company and products, and a member section where customers can access their information. Only the email address and physical address need to be provided as part of the registration process in order to customize the site to the user's region and country. There is also a newsletter sent every month to all members featuring fitness tips, nutrition advice, product spotlights from partner companies based on user behavior and preferences.

Jordan says the General Data Protection Regulation (GDPR) does not apply to the company. He says the company is not established in the EU, nor does it have a processor in the region. Furthermore, it does not do any "offering goods or services" in the EU since it does not do any marketing there, nor sell to consumers directly. Jordan argues that it is the customers who chose to buy the products on their own initiative and there is no "offering" from the company.

The fitness trackers incorporate advanced features such as sleep tracking, GPS tracking, heart rate monitoring, wireless syncing, calorie-counting and step-tracking. The watch must be paired with either a smartphone or a computer in order to collect data on sleep levels, heart rates, etc. All information from the device must be sent to the company's servers in order to be processed, and then the results are sent to the smartphone or computer. Jordan argues that there is no personal information involved since the company does not collect banking or social security information. Based on the current features of the fitness watch, what would you recommend be implemented into each device in order to most effectively ensure privacy?

- (A). Hashing.
- (B). A2DP Bluetooth profile.
- (C). Persistent unique identifier.
- (D). Randomized MAC address.

Answer: C

NO.51 When analyzing user data, how is differential privacy applied?

- (A). By injecting noise into aggregated datasets.
- (B). By assessing differences between datasets.
- (C). By applying asymmetric encryption to datasets.
- (D). By removing personal identifiers from datasets.

Answer: A

NO.52 SCENARIO

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file. Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine. After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

What is the strongest method for authenticating Chuck's identity prior to allowing access to his violation information through the AMP Payment Resources web portal?

- (A). By requiring Chuck use the last 4 digits of his driver's license number in combination with a unique PIN provided within the violation notice.
- (B). By requiring Chuck use his credit card number in combination with the last 4 digits of his driver's license.
- (C). By requiring Chuck use the rental agreement number in combination with his email address.
- (D). By requiring Chuck to call AMP Payment Resources directly and provide his date of birth and home address.

Answer: D

NO.53 SCENARIO

Wesley Energy has finally made its move, acquiring the venerable oil and gas exploration firm Lancelot from its long-time owner David Wilson. As a member of the transition team, you have come to realize that Wilson's quirky nature affected even Lancelot's data practices, which are maddeningly inconsistent. "The old man hired and fired IT people like he was changing his necktie," one of Wilson's seasoned lieutenants tells you, as you identify the traces of initiatives left half complete. For instance, while some proprietary data and personal information on clients and employees is encrypted, other sensitive information, including health information from surveillance testing of employees for toxic exposures, remains unencrypted, particularly when included within longer records with less-sensitive data. You also find that data is scattered across applications, servers and facilities in a manner that at first glance seems almost random.

Among your preliminary findings of the condition of data at Lancelot are the following:

Cloud technology is supplied by vendors around the world, including firms that you have not heard of. You are told by a former Lancelot employee that these vendors operate with divergent security

requirements and protocols.

The company's proprietary recovery process for shale oil is stored on servers among a variety of less-sensitive information that can be accessed not only by scientists, but by personnel of all types at most company locations.

DES is the strongest encryption algorithm currently used for any file.

Several company facilities lack physical security controls, beyond visitor check-in, which familiar vendors often bypass.

Fixing all of this will take work, but first you need to grasp the scope of the mess and formulate a plan of action to address it.

Which is true regarding the type of encryption Lancelot uses?

- (A). It employs the data scrambling technique known as obfuscation.
- (B). Its decryption key is derived from its encryption key.
- (C). It uses a single key for encryption and decryption.
- (D). It is a data masking methodology.

Answer: A

NO.54 SCENARIO

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis. LBH also implements Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) for the new Light Blue Health application currently in development. Which of the following best describes a risk that is likely to result in a privacy breach?

- (A). Limiting access to the app to authorized personnel.
- (B). Including non-transparent policies, terms and conditions in the app.
- (C). Insufficiently deleting personal data after an account reaches its retention period.
- (D). Not encrypting the health record when it is transferred to the Light Blue Health servers.

Answer: A

NO.55 Which of the following is a vulnerability of a sensitive biometrics authentication system?

- (A). False positives.
- (B). False negatives.
- (C). Slow recognition speeds.
- (D). Theft of finely individualized personal data.

Answer: C

NO.56 Which of the following became a foundation for privacy principles and practices of countries and organizations across the globe?

- (A). The Personal Data Ordinance.
- (B). The EU Data Protection Directive.
- (C). The Code of Fair Information Practices.
- (D). The Organization for Economic Co-operation and Development (OECD) Privacy Principles.

Answer: D

NO.57 Which of the following statements describes an acceptable disclosure practice?

- (A). An organization's privacy policy discloses how data will be used among groups within the organization itself.
- (B). With regard to limitation of use, internal disclosure policies override contractual agreements with third parties.
- (C). Intermediaries processing sensitive data on behalf of an organization require stricter disclosure oversight than vendors.
- (D). When an organization discloses data to a vendor, the terms of the vendor's privacy notice prevail over the organization's privacy notice.

Answer: A

NO.58 What privacy risk is NOT mitigated by the use of encrypted computation to target and serve online ads?

- (A). The ad being served to the user may not be relevant.
- (B). The user's sensitive personal information is used to display targeted ads.
- (C). The personal information used to target ads can be discerned by the server.
- (D). The user's information can be leaked to an advertiser through weak de-identification techniques.

Answer: D

NO.59 What was the first privacy framework to be developed?

- (A). OECD Privacy Principles.
- (B). Generally Accepted Privacy Principles.
- (C). Code of Fair Information Practice Principles (FIPPs).
- (D). The Asia-Pacific Economic Cooperation (APEC) Privacy Framework.

Answer: A

NO.60 What is the potential advantage of homomorphic encryption?

- (A). Encrypted information can be analyzed without decrypting it first.
- (B). Ciphertext size decreases as the security level increases.
- (C). It allows greater security and faster processing times.
- (D). It makes data impenetrable to attacks.

Answer: C

NO.61 Which is NOT a way to validate a person's identity?

- (A). Swiping a smartcard into an electronic reader.
- (B). Using a program that creates random passwords.
- (C). Answering a question about "something you know".
- (D). Selecting a picture and tracing a unique pattern on it

Answer: B

NO.62 Which of the following functionalities can meet some of the General Data Protection Regulation's (GDPR's) Data Portability requirements for a social networking app designed for users in the EU?

- (A). Allow users to modify the data they provided the app.
- (B). Allow users to delete the content they provided the app.
- (C). Allow users to download the content they have provided the app.
- (D). Allow users to get a time-stamped list of what they have provided the app.

Answer: C

NO.63 SCENARIO

You have just been hired by Ancillary.com, a seller of accessories for everything under the sun, including waterproof stickers for pool floats and decorative bands and cases for sunglasses. The company sells cell phone cases, e-cigarette cases, wine spouts, hanging air fresheners for homes and automobiles, book ends, kitchen implements, visors and shields for computer screens, passport holders, gardening tools and lawn ornaments, and catalogs full of health and beauty products. The list seems endless. As the CEO likes to say, Ancillary offers, without doubt, the widest assortment of low-price consumer products from a single company anywhere.

Ancillary's operations are similarly diverse. The company originated with a team of sales consultants selling home and beauty products at small parties in the homes of customers, and this base business is still thriving. However, the company now sells online through retail sites designated for industries and demographics, sites such as "My Cool Ride" for automobile-related products or "Zoomer" for gear aimed toward young adults. The company organization includes a plethora of divisions, units and outrigger operations, as Ancillary has been built along a decentered model rewarding individual initiative and flexibility, while also acquiring key assets. The retail sites seem to all function differently, and you wonder about their compliance with regulations and industry standards. Providing tech support to these sites is also a challenge, partly due to a variety of logins and authentication protocols.

You have been asked to lead three important new projects at Ancillary:

The first is the personal data management and security component of a multi-faceted initiative to unify the company's culture. For this project, you are considering using a series of third-party servers to provide company data and approved applications to employees.

The second project involves providing point of sales technology for the home sales force, allowing them to move beyond paper checks and manual credit card imprinting.

Finally, you are charged with developing privacy protections for a single web store housing all the company's product lines as well as products from affiliates. This new omnibus site will be known, aptly, as "Under the Sun." The Director of Marketing wants the site not only to sell Ancillary's products, but to link to additional products from other retailers through paid advertisements. You

need to brief the executive team of security concerns posed by this approach.

If you are asked to advise on privacy concerns regarding paid advertisements, which is the most important aspect to cover?

- (A). Unseen web beacons that combine information on multiple users.
- (B). Latent keys that trigger malware when an advertisement is selected.
- (C). Personal information collected by cookies linked to the advertising network.
- (D). Sensitive information from Structured Query Language (SQL) commands that may be exposed.

Answer: C

NO.64 What is the main function of a breach response center?

- (A). Detecting internal security attacks.
- (B). Addressing privacy incidents.
- (C). Providing training to internal constituencies.
- (D). Interfacing with privacy regulators and governmental bodies.

Answer: B

NO.65 A vendor has been collecting data under an old contract, not aligned with the practices of the organization.

Which is the preferred response?

- (A). Destroy the data
- (B). Update the contract to bring the vendor into alignment.
- (C). Continue the terms of the existing contract until it expires.
- (D). Terminate the contract and begin a vendor selection process.

Answer: B

NO.66 Which of the following would be the best method of ensuring that Information Technology projects follow Privacy by Design (PbD) principles?

- (A). Develop a technical privacy framework that integrates with the development lifecycle.
- (B). Utilize Privacy Enhancing Technologies (PETs) as a part of product risk assessment and management.
- (C). Identify the privacy requirements as a part of the Privacy Impact Assessment (PIA) process during development and evaluation stages.
- (D). Develop training programs that aid the developers in understanding how to turn privacy requirements into actionable code and design level specifications.

Answer: D

NO.67 Which of the following are the mandatory pieces of information to be included in the documentation of **records of processing activities for an organization** that processes personal data on behalf of another organization?

- (A). Copies of the consent forms from each data subject.
- (B). Time limits for erasure of different categories of data.
- (C). Contact details of the processor and Data Protection Officer (DPO).
- (D). Descriptions of the processing activities and relevant data subjects.

Answer: B

NO.68 Value Sensitive Design (VSD) focuses on which of the following?

- (A). Quality and benefit.
- (B). Ethics and morality.
- (C). Principles and standards.
- (D). Privacy and human rights.

Answer: C

NO.69 What is the most important requirement to fulfill when transferring data out of an organization?

- (A). Ensuring the organization sending the data controls how the data is tagged by the receiver.
- (B). Ensuring the organization receiving the data performs a privacy impact assessment.
- (C). Ensuring the commitments made to the data owner are followed.
- (D). Extending the data retention schedule as needed.

Answer: C

NO.70 SCENARIO

You have just been hired by Ancillary.com, a seller of accessories for everything under the sun, including waterproof stickers for pool floats and decorative bands and cases for sunglasses. The company sells cell phone cases, e-cigarette cases, wine spouts, hanging air fresheners for homes and automobiles, book ends, kitchen implements, visors and shields for computer screens, passport holders, gardening tools and lawn ornaments, and catalogs full of health and beauty products. The list seems endless. As the CEO likes to say, Ancillary offers, without doubt, the widest assortment of low-price consumer products from a single company anywhere.

Ancillary's operations are similarly diverse. The company originated with a team of sales consultants selling home and beauty products at small parties in the homes of customers, and this base business is still thriving. However, the company now sells online through retail sites designated for industries and demographics, sites such as "My Cool Ride" for automobile-related products or "Zoomer" for gear aimed toward young adults. The company organization includes a plethora of divisions, units and outrigger operations, as Ancillary has been built along a decentered model rewarding individual initiative and flexibility, while also acquiring key assets. The retail sites seem to all function differently, and you wonder about their compliance with regulations and industry standards. Providing tech support to these sites is also a challenge, partly due to a variety of logins and authentication protocols.

You have been asked to lead three important new projects at Ancillary:

The first is the personal data management and security component of a multi-faceted initiative to unify the company's culture. For this project, you are considering using a series of third-party servers to provide company data and approved applications to employees.

The second project involves providing point of sale technology for the home sales force, allowing them to move beyond paper checks and manual credit card imprinting.

Finally, you are charged with developing privacy protections for a single web store housing all the company's product lines as well as products from affiliates. This new omnibus site will be known, aptly, as "Under the Sun." The Director of Marketing wants the site not only to sell Ancillary's products, but to link to additional products from other retailers through paid advertisements. You need to brief the executive team of security concerns posed by this approach.

What technology is under consideration in the first project in this scenario?

- (A). Server driven controls.
- (B). Cloud computing
- (C). Data on demand
- (D). MAC filtering

Pass4leader.com

Answer: A

NO.71 Which of the following entities would most likely be exempt from complying with the General Data Protection Regulation (GDPR)?

- (A). A South American company that regularly collects European customers' personal data.
- (B). A company that stores all customer data in Australia and is headquartered in a European Union (EU) member state.
- (C). A Chinese company that has opened a satellite office in a European Union (EU) member state to service European customers.
- (D). A North American company servicing customers in South Africa that uses a cloud storage system made by a European company.

Answer: C

NO.72 SCENARIO

Tom looked forward to starting his new position with a U.S.-based automobile leasing company (New Company), now operating in 32 states. New Company was recently formed through the merger of two prominent players, one from the eastern region (East Company) and one from the western region (West Company). Tom, a Certified Information Privacy Technologist (CIPT), is New Company's first Information Privacy and Security Officer. He met today with Dick from East Company, and Harry, from West Company. Dick and Harry are veteran senior information privacy and security professionals at their respective companies, and continue to lead the east and west divisions of New Company. The purpose of the meeting was to conduct a SWOT (strengths/weaknesses/opportunities/threats) analysis for New Company. Their SWOT analysis conclusions are summarized below.

Dick was enthusiastic about an opportunity for the New Company to reduce costs and increase computing power and flexibility through cloud services. East Company had been contemplating moving to the cloud, but West Company already had a vendor that was providing it with software-as-a-service (SaaS). Dick was looking forward to extending this service to the eastern region. Harry noted that this was a threat as well, because West Company had to rely on the third party to protect its data.

Tom mentioned that neither of the legacy companies had sufficient data storage space to meet the projected growth of New Company, which he saw as a weakness. Tom stated that one of the team's first projects would be to construct a consolidated New Company data warehouse. Tom would personally lead this project and would be held accountable if information was modified during transmission to or during storage in the new data warehouse.

Tom, Dick and Harry agreed that employee network access could be considered both a strength and a weakness. East Company and West Company had strong performance records in this regard; both had robust network access controls that were working as designed. However, during a projected year-long transition period, New Company employees would need to be able to connect to a New Company network while retaining access to the East Company and West Company networks.

When employees are working remotely, they usually connect to a Wi-Fi network. What should Harry advise for maintaining company security in this situation?

- (A). Hiding wireless service set identifiers (SSID).
- (B). Retaining the password assigned by the network.
- (C). Employing Wired Equivalent Privacy (WEP) encryption.
- (D). Using tokens sent through HTTP sites to verify user identity.

Answer: A

NO.73 In the realm of artificial intelligence, how has deep learning enabled greater implementation of machine learning?

- (A). By using hand-coded classifiers like edge detection filters so that a program can identify where an object starts and stops.
- (B). By increasing the size of neural networks and running massive amounts of data through the network to train it.
- (C). By using algorithmic approaches such as decision tree learning and inductive logic programming.
- (D). By hand coding software routines with a specific set of instructions to accomplish a task.

Answer: B

NO.74 SCENARIO

Please use the following to answer the next question:

Jordan just joined a fitness-tracker start-up based in California, USA, as its first Information Privacy and Security Officer. The company is quickly growing its business but does not sell any of the fitness trackers itself. Instead, it relies on a distribution network of third-party retailers in all major countries. Despite not having any stores, the company has a 78% market share in the EU. It has a website presenting the company and products, and a member section where customers can access their information. Only the email address and physical address need to be provided as part of the registration process in order to customize the site to the user's region and country. There is also a newsletter sent every month to all members featuring fitness tips, nutrition advice, product spotlights from partner companies based on user behavior and preferences.

Jordan says the General Data Protection Regulation (GDPR) does not apply to the company. He says the company is not established in the EU, nor does it have a processor in the region. Furthermore, it does not do any "offering goods or services" in the EU since it does not do any marketing there, nor sell to consumers directly. Jordan argues that it is the customers who chose to buy the products on their own initiative and there is no "offering" from the company.

The fitness trackers incorporate advanced features such as sleep tracking, GPS tracking, heart rate monitoring, wireless syncing, calorie-counting and step-tracking. The watch must be paired with either a smartphone or a computer in order to collect data on sleep levels, heart rates, etc. All information from the device must be sent to the company's servers in order to be processed, and then the results are sent to the smartphone or computer. Jordan argues that there is no personal information involved since the company does not collect banking or social security information. Why is Jordan's claim that the company does not collect personal information as identified by the GDPR inaccurate?

- (A). The potential customers must browse for products online.
- (B). The fitness trackers capture sleep and heart rate data to monitor an individual's behavior.
- (C). The website collects the customers' and users' region and country information.
- (D). The customers must pair their fitness trackers to either smartphones or computers.

Answer: A

NO.75 SCENARIO

Kyle is a new security compliance manager who will be responsible for coordinating and executing controls to ensure compliance with the company's information security policy and industry standards. Kyle is also new to the company, where collaboration is a core value. On his first day of new-hire orientation, Kyle's schedule included participating in meetings and observing work in the IT and compliance departments.

Kyle spent the morning in the IT department, where the CIO welcomed him and explained that her department was responsible for IT governance. The CIO and Kyle engaged in a conversation about the importance of identifying meaningful IT governance metrics. Following their conversation, the CIO introduced Kyle to Ted and Barney. Ted is implementing a plan to encrypt data at the transportation level of the organization's wireless network. Kyle would need to get up to speed on the project and suggest ways to monitor effectiveness once the implementation was complete. Barney explained that his short-term goals are to establish rules governing where data can be placed and to minimize the use of offline data storage.

Kyle spent the afternoon with Jill, a compliance specialist, and learned that she was exploring an initiative for a compliance program to follow self-regulatory privacy principles. Thanks to a recent internship, Kyle had some experience in this area and knew where Jill could find some support. Jill also shared results of the company's privacy risk assessment, noting that the secondary use of personal information was considered a high risk.

By the end of the day, Kyle was very excited about his new job and his new company. In fact, he learned about an open position for someone with strong qualifications and experience with access privileges, project standards board approval processes, and application-level obligations, and couldn't wait to recommend his friend Ben who would be perfect for the job.

Which data practice is Barney most likely focused on improving?

- (A). Deletion
- (B). Inventory.
- (C). Retention.
- (D). Sharing

Answer: C

NO.76 SCENARIO

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file. Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the

driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine.

After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

What is the most secure method Finley Motors should use to transmit Chuck's information to AMP Payment Resources?

- (A). Cloud file transfer services.
- (B). Certificate Authority (CA).
- (C). HyperText Transfer Protocol (HTTP).
- (D). Transport Layer Security (TLS).

Answer: D

NO.77 What is the main reason the Do Not Track (DNT) header is not acknowledged by more companies?

- (A). Most web browsers incorporate the DNT feature.
- (B). The financial penalties for violating DNT guidelines are too high.
- (C). There is a lack of consensus about what the DNT header should mean.
- (D). It has been difficult to solve the technological challenges surrounding DNT.

Answer: C

NO.78 What is the main benefit of using a private cloud?

- (A). The ability to use a backup system for personal files.
- (B). The ability to outsource data support to a third party.
- (C). The ability to restrict data access to employees and contractors.
- (D). The ability to cut costs for storing, maintaining, and accessing data.

Answer: C

NO.79 An organization based in California, USA is implementing a new online helpdesk solution for recording customer call information. The organization considers the capture of personal data on the online helpdesk solution to be in the interest of the company in best servicing customer calls.

Before implementation, a privacy technologist should conduct which of the following?

- (A). A Data Protection Impact Assessment (DPIA) and consultation with the appropriate regulator to ensure legal compliance.
- (B). A privacy risk and impact assessment to evaluate potential risks from the proposed processing operations.
- (C). A Legitimate Interest Assessment (LIA) to ensure that the processing is proportionate and does not override the privacy, rights and freedoms of the customers.
- (D). A security assessment of the help desk solution and provider to assess if the technology was developed with a security by design approach.

Answer: C

NO.80 Which of the following CANNOT be effectively determined during a code audit?

- (A). Whether access control logic is recommended in all cases.
- (B). Whether data is being incorrectly shared with a third-party.
- (C). Whether consent is durably recorded in the case of a server crash.
- (D). Whether the differential privacy implementation correctly anonymizes data.

Answer: D

NO.81 Which of the following would best improve an organization's system of limiting data use?

- (A). Implementing digital rights management technology.
- (B). Confirming implied consent for any secondary use of data.
- (C). Applying audit trails to resources to monitor company personnel.
- (D). Instituting a system of user authentication for company personnel.

Answer: C

NO.82 How should the sharing of information within an organization be documented?

- (A). With a binding contract.
- (B). With a data flow diagram.
- (C). With a disclosure statement.
- (D). With a memorandum of agreement.

Answer: C

NO.83 Which of the following statements best describes the relationship between privacy and security?

- (A). Security systems can be used to enforce compliance with privacy policies.
- (B). Privacy and security are independent; organizations must decide which should be emphasized.
- (C). Privacy restricts access to personal information; security regulates how information should be used.
- (D). Privacy protects data from being viewed during collection and security governs how collected data should be shared.

Answer: C

NO.84 How can a hacker gain control of a smartphone to perform remote audio and video surveillance?

- (A). By performing cross-site scripting.
- (B). By installing a roving bug on the phone.
- (C). By manipulating geographic information systems.
- (D). By accessing a phone's global positioning system satellite signal.

Answer: B

NO.85 What has been identified as a significant privacy concern with chatbots?

- (A). Most chatbot providers do not agree to code audits
- (B). Chatbots can easily verify the identity of the contact.
- (C). Users' conversations with chatbots are not encrypted in transit.
- (D). Chatbot technology providers may be able to read chatbot conversations with users.

Answer: D

NO.86 Properly configured databases and well-written website codes are the best protection against

what online threat?

- (A). Pharming.
- (B). SQL injection.
- (C). Malware execution.
- (D). System modification.

Answer: B

NO.87 What is the main privacy threat posed by Radio Frequency Identification (RFID)?

- (A). An individual with an RFID receiver can track people or consumer products.
- (B). An individual can scramble computer transmissions in weapons systems.
- (C). An individual can use an RFID receiver to engage in video surveillance.
- (D). An individual can tap mobile phone communications.

Answer: D

NO.88 What must be used in conjunction with disk encryption?

- (A). Increased CPU speed.
- (B). A strong password.
- (C). A digital signature.
- (D). Export controls.

Answer: C

NO.89 A privacy engineer reviews a newly developed on-line registration page on a company's website. The purpose of the page is to enable corporate customers to submit a returns / refund request for physical goods. The page displays the following data capture fields: company name, account reference, company address, contact name, email address, contact phone number, product name, quantity, issue description and company bank account details.

After her review, the privacy engineer recommends setting certain capture fields as "non-mandatory". Setting which of the following fields as "non-mandatory" would be the best example of the principle of data minimization?

- (A). The contact phone number field.
- (B). The company address and name.
- (C). The contact name and email address.
- (D). The company bank account detail field.

Answer: B

NO.90 SCENARIO

WebTracker Limited is a cloud-based online marketing service located in London. Last year, WebTracker migrated its IT infrastructure to the cloud provider AmaZure, which provides SQL Databases and Artificial Intelligence services to WebTracker. The roles and responsibilities between the two companies have been formalized in a standard contract, which includes allocating the role of data controller to WebTracker.

The CEO of WebTracker, Mr. Bond, would like to assess the effectiveness of AmaZure's privacy controls, and he recently decided to hire you as an independent auditor. The scope of the engagement is limited only to the marketing services provided by WebTracker, you will not be evaluating any internal data processing activity, such as HR or Payroll.

This ad-hoc audit was triggered due to a future partnership between WebTracker and SmartHome - a

partnership that will not require any data sharing. SmartHome is based in the USA, and most recently has dedicated substantial resources to developing smart refrigerators that can suggest the recommended daily calorie intake based on DNA information. This and other personal data is collected by WebTracker.

To get an idea of the scope of work involved, you have decided to start reviewing the company's documentation and interviewing key staff to understand potential privacy risks.

The results of this initial work include the following notes:

There are several typos in the current privacy notice of WebTracker, and you were not able to find the privacy notice for SmartHome.

You were unable to identify all the sub-processors working for SmartHome. No subcontractor is indicated in the cloud agreement with AmaZure, which is responsible for the support and maintenance of the cloud infrastructure.

There are data flows representing personal data being collected from the internal employees of WebTracker, including an interface from the HR system.

Part of the DNA data collected by WebTracker was from employees, as this was a prototype approved by the CEO of WebTracker.

All the WebTracker and SmartHome customers are based in USA and Canada.

Based on the initial assessment and review of the available data flows, which of the following would be the most important privacy risk you should investigate first?

- (A). Verify that WebTracker's HR and Payroll systems implement the current privacy notice (after the typos are fixed).
- (B). Review the list of subcontractors employed by AmaZure and ensure these are included in the formal agreement with WebTracker.
- (C). Evaluate and review the basis for processing employees' personal data in the context of the prototype created by WebTracker and approved by the CEO.
- (D). Confirm whether the data transfer from London to the USA has been fully approved by AmaZure and the appropriate institutions in the USA and the European Union.

Answer: C

NO.91 Which of the following provides a mechanism that allows an end-user to use a single sign-on (SSO) for multiple services?

- (A). The Open ID Federation.
- (B). PCI Data Security Standards Council
- (C). International Organization for Standardization.
- (D). Personal Information Protection and Electronic Documents Act.

Answer: A

NO.92 Which of these actions is NOT generally part of the responsibility of an IT or software engineer?

- (A). Providing feedback on privacy policies.
- (B). Implementing multi-factor authentication.
- (C). Certifying compliance with security and privacy law.
- (D). Building privacy controls into the organization's IT systems or software.

Answer: A

NO.93 What is an Access Control List?

- (A). A list of steps necessary for an individual to access a resource.
- (B). A list that indicates the type of permission granted to each individual.
- (C). A list showing the resources that an individual has permission to access.
- (D). A list of individuals who have had their access privileges to a resource revoked.

Answer: C

NO.94 What is an example of a just-in-time notice?

- (A). A warning that a website may be unsafe.
- (B). A full organizational privacy notice publicly available on a website
- (C). A credit card company calling a user to verify a purchase before it is authorized
- (D). Privacy information given to a user when he attempts to comment on an online article.

Answer: D

NO.95 Which of the following is the best method to minimize tracking through the use of cookies?

- (A). Use 'private browsing' mode and delete checked files, clear cookies and cache once a day.
- (B). Install a commercially available third-party application on top of the browser that is already installed.
- (C). Install and use a web browser that is advertised as 'built specifically to safeguard user privacy'.
- (D). Manage settings in the browser to limit the use of cookies and remove them once the session completes.

Answer: D

NO.96 What has been found to undermine the public key infrastructure system?

- (A). Man-in-the-middle attacks.
- (B). Inability to track abandoned keys.
- (C). Disreputable certificate authorities.
- (D). Browsers missing a copy of the certificate authority's public key.

Answer: D

NO.97 Which of the following is considered a client-side IT risk?

- (A). Security policies focus solely on internal corporate obligations.
- (B). An organization increases the number of applications on its server.
- (C). An employee stores his personal information on his company laptop.
- (D). IDs used to avoid the use of personal data map to personal data in another database.

Answer: C

NO.98 What is the goal of privacy enhancing technologies (PETs) like multiparty computation and differential privacy?

- (A). To facilitate audits of third party vendors.
- (B). To protect sensitive data while maintaining its utility.
- (C). To standardize privacy activities across organizational groups.
- (D). To protect the security perimeter and the data items themselves.

Answer: B

NO.99 SCENARIO

You have just been hired by Ancillary.com, a seller of accessories for everything under the sun,

including waterproof stickers for pool floats and decorative bands and cases for sunglasses. The company sells cell phone cases, e-cigarette cases, wine spouts, hanging air fresheners for homes and automobiles, book ends, kitchen implements, visors and shields for computer screens, passport holders, gardening tools and lawn ornaments, and catalogs full of health and beauty products. The list seems endless. As the CEO likes to say, Ancillary offers, without doubt, the widest assortment of low-price consumer products from a single company anywhere.

Ancillary's operations are similarly diverse. The company originated with a team of sales consultants selling home and beauty products at small parties in the homes of customers, and this base business is still thriving. However, the company now sells online through retail sites designated for industries and demographics, sites such as "My Cool Ride" for automobile-related products or "Zoomer" for gear aimed toward young adults. The company organization includes a plethora of divisions, units and outrigger operations, as Ancillary has been built along a decentered model rewarding individual initiative and flexibility, while also acquiring key assets. The retail sites seem to all function differently, and you wonder about their compliance with regulations and industry standards. Providing tech support to these sites is also a challenge, partly due to a variety of logins and authentication protocols.

You have been asked to lead three important new projects at Ancillary:

The first is the personal data management and security component of a multi-faceted initiative to unify the company's culture. For this project, you are considering using a series of third-party servers to provide company data and approved applications to employees.

The second project involves providing point of sales technology for the home sales force, allowing them to move beyond paper checks and manual credit card imprinting.

Finally, you are charged with developing privacy protections for a single web store housing all the company's product lines as well as products from affiliates. This new omnibus site will be known, aptly, as "Under the Sun." The Director of Marketing wants the site not only to sell Ancillary's products, but to link to additional products from other retailers through paid advertisements. You need to brief the executive team of security concerns posed by this approach.

Which should be used to allow the home sales force to accept payments using smartphones?

- (A). Field transfer protocol.
- (B). Cross-current translation.
- (C). Near-field communication
- (D). Radio Frequency Identification

Answer: C

NO.100 To comply with the Sarbanes-Oxley Act (SOX), public companies in the United States are required to annually report on the effectiveness of the auditing controls of their financial reporting systems. These controls must be implemented to prevent unauthorized use, disclosure, modification, and damage or loss of financial data.

Why do these controls ensure both the privacy and security of data?

- (A). Modification of data is an aspect of privacy; unauthorized use, disclosure, and damage or loss of data are aspects of security.
- (B). Unauthorized use of data is an aspect of privacy; disclosure, modification, and damage or loss of data are aspects of security.
- (C). Disclosure of data is an aspect of privacy; unauthorized use, modification, and damage or loss of data are aspects of security.
- (D). Damage or loss of data are aspects of privacy; disclosure, unauthorized use, and modification of data are aspects of privacy.

Answer: C

NO.101 Revocation and reissuing of compromised credentials is impossible for which of the following authentication techniques?

- (A). Biometric data.
- (B). Picture passwords.
- (C). Personal identification number.
- (D). Radio frequency identification.

Answer: D

NO.102 Which of the following most embodies the principle of Data Protection by Default?

- (A). A messaging app for high school students that uses HTTPS to communicate with the server.
- (B). An electronic teddy bear with built-in voice recognition that only responds to its owner's voice.
- (C). An internet forum for victims of domestic violence that allows anonymous posts without registration.
- (D). A website that has an opt-in form for marketing emails when registering to download a whitepaper.

Answer: D

NO.103 Aadhaar is a unique-identity number of 12 digits issued to all Indian residents based on their biometric and demographic data. The data is collected by the Unique Identification Authority of India. The Aadhaar database contains the Aadhaar number, name, date of birth, gender and address of over 1 billion individuals.

Which of the following datasets derived from that data would be considered the most de-identified?

- (A). A count of the years of birth and hash of the person's gender.
- (B). A count of the month of birth and hash of the person's first name.
- (C). A count of the day of birth and hash of the person's first initial of their first name.
- (D). Account of the century of birth and hash of the last 3 digits of the person's Aadhaar number.

Answer: C

NO.104 A valid argument against data minimization is that it?

- (A). Can limit business opportunities.
- (B). Decreases the speed of data transfers.
- (C). Can have an adverse effect on data quality.
- (D). Increases the chance that someone can be identified from data.

Answer: A

NO.105 SCENARIO

Please use the following to answer the next question:

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the St. Anne's Regional Medical Center in Thorn Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data—not only records produced recently, but those still on-hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You recall a recent visit to the Records Storage Section in the basement of the old hospital next to the modern facility, where you noticed paper records sitting in crates labeled by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. On the back shelves of the section sat data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the records storage section, you noticed a man leaving whom you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

You quickly realize that you need a plan of action on the maintenance, secure storage and disposal of data.

Which cryptographic standard would be most appropriate for protecting patient credit card information in the records system at St. Anne's Regional Medical Center?

- (A). Symmetric Encryption
- (B). Tokenization
- (C). Obfuscation
- (D). Certificates

Answer: B

NO.106 SCENARIO

It should be the most secure location housing data in all of Europe, if not the world. The Global Finance Data Collective (GFDC) stores financial information and other types of client data from large banks, insurance companies, multinational corporations and governmental agencies. After a long climb on a mountain road that leads only to the facility, you arrive at the security booth. Your credentials are checked and checked again by the guard to visually verify that you are the person pictured on your passport and national identification card. You are led down a long corridor with server rooms on each side, secured by combination locks built into the doors. You climb a flight of stairs and are led into an office that is lighted brilliantly by skylights where the GFDC Director of Security, Dr. Monique Batch, greets you. On the far wall you notice a bank of video screens showing different rooms in the facility. At the far end, several screens show different sections of the road up the mountain Dr. Batch explains once again your mission. As a data security auditor and consultant, it is a dream assignment: The GFDC does not want simply adequate controls, but the best and most effective security that current technologies allow.

"We were hacked twice last year," Dr. Batch says, "and although only a small number of records were stolen, the bad press impacted our business. Our clients count on us to provide security that is

nothing short of impenetrable and to do so quietly. We hope to never make the news again." She notes that it is also essential that the facility is in compliance with all relevant security regulations and standards.

You have been asked to verify compliance as well as to evaluate all current security controls and security measures, including data encryption methods, authentication controls and the safest methods for transferring data into and out of the facility. As you prepare to begin your analysis, you find yourself considering an intriguing question: Can these people be sure that I am who I say I am? You are shown to the office made available to you and are provided with system login information, including the name of the wireless network and a wireless key. Still pondering, you attempt to pull up the facility's wireless network, but no networks appear in the wireless list. When you search for the wireless network by name, however it is readily found.

What measures can protect client information stored at GFDC?

- (A). De-linking of data into client-specific packets.
- (B). Cloud-based applications.
- (C). Server-side controls.
- (D). Data pruning

Answer: A

NO.107 Which of the following is considered a records management best practice?

- (A). Archiving expired data records and files.
- (B). Storing decryption keys with their associated backup systems.
- (C). Implementing consistent handling practices across all record types.
- (D). Using classification to determine access rules and retention policy.

Answer: D

NO.108 Which Organization for Economic Co-operation and Development (OECD) privacy protection principle encourages an organization to obtain an individual's consent before transferring personal information?

- (A). Individual participation.
- (B). Purpose specification.
- (C). Collection limitation.
- (D). Accountability.

Answer: C

NO.109 Which of the following suggests the greatest degree of transparency?

- (A). A privacy disclosure statement clearly articulates general purposes for collection
- (B). The data subject has multiple opportunities to opt-out after collection has occurred.
- (C). A privacy notice accommodates broadly defined future collections for new products.
- (D). After reading the privacy notice, a data subject confidently infers how her information will be used.

Answer: D

NO.110 Which of the following is an example of the privacy risks associated with the Internet of Things (IoT)?

- (A). A group of hackers infiltrate a power grid and cause a major blackout.
- (B). An insurance company raises a person's rates based on driving habits gathered from a connected car.
- (C). A website stores a cookie on a user's hard drive so the website can recognize the user on subsequent visits.
- (D). A water district fines an individual after a meter reading reveals excess water use during drought conditions.

Answer: B

NO.111 SCENARIO

It should be the most secure location housing data in all of Europe, if not the world. The Global Finance Data Collective (GFDC) stores financial information and other types of client data from large banks, insurance companies, multinational corporations and governmental agencies. After a long climb on a mountain road that leads only to the facility, you arrive at the security booth. Your credentials are checked and checked again by the guard to visually verify that you are the person pictured on your passport and national identification card. You are led down a long corridor with server rooms on each side, secured by combination locks built into the doors. You climb a flight of stairs and are led into an office that is lighted brilliantly by skylights where the GFDC Director of Security, Dr. Monique Batch, greets you. On the far wall you notice a bank of video screens showing different rooms in the facility. At the far end, several screens show different sections of the road up the mountain Dr. Batch explains once again your mission. As a data security auditor and consultant, it is a dream assignment: The GFDC does not want simply adequate controls, but the best and most effective security that current technologies allow.

"We were hacked twice last year," Dr. Batch says, "and although only a small number of records were stolen, the bad press impacted our business. Our clients count on us to provide security that is nothing short of impenetrable and to do so quietly. We hope to never make the news again." She notes that it is also essential that the facility is in compliance with all relevant security regulations and standards.

You have been asked to verify compliance as well as to evaluate all current security controls and security measures, including data encryption methods, authentication controls and the safest methods for transferring data into and out of the facility. As you prepare to begin your analysis, you find yourself considering an intriguing question: Can these people be sure that I am who I say I am? You are shown to the office made available to you and are provided with system login information, including the name of the wireless network and a wireless key. Still pondering, you attempt to pull up the facility's wireless network, but no networks appear in the wireless list. When you search for the wireless network by name, however it is readily found.

Why would you recommend that GFC use record encryption rather than disk, file or table encryption ?

- (A). Record encryption is asymmetric, a stronger control measure.
- (B). Record encryption is granular, limiting the damage of potential breaches.
- (C). Record encryption involves tag masking, so its metadata cannot be decrypted
- (D). Record encryption allows for encryption of personal data only.

Answer: B

NO.112 Between November 30th and December 2nd, 2013, cybercriminals successfully infected the credit card payment systems and bypassed security controls of a United States-based retailer with

malware that exfiltrated 40 million credit card numbers. Six months prior, the retailer had malware detection software installed to prevent against such an attack.

Which of the following would best explain why the retailer's consumer data was still exfiltrated?

- (A). The detection software alerted the retailer's security operations center per protocol, but the information security personnel failed to act upon the alerts.
- (B). The U.S Department of Justice informed the retailer of the security breach on Dec. 12th, but the retailer took three days to confirm the breach and eradicate the malware.
- (C). The IT systems and security measures utilized by the retailer's third-party vendors were in compliance with industry standards, but their credentials were stolen by black hat hackers who then entered the retailer's system.
- (D). The retailer's network that transferred personal data and customer payments was separate from the rest of the corporate network, but the malware code was disguised with the name of software that is supposed to protect this information.

Answer: B

NO.113 An EU marketing company is planning to make use of personal data captured to make automated decisions based on profiling. In some cases, processing and automated decisions may have a legal effect on individuals, such as credit worthiness.

When evaluating the implementation of systems making automated decisions, in which situation would the company have to accommodate an individual's right NOT to be subject to such processing to ensure compliance under the General Data Protection Regulation (GDPR)?

- (A). When an individual's legal status or rights are not affected by the decision.
- (B). When there is no human intervention or influence in the decision-making process.
- (C). When the individual has given explicit consent to such processing and suitable safeguards exist.
- (D). When the decision is necessary for entering into a contract and the individual can contest the decision.

Answer: B

NO.114 SCENARIO

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clean-Q invited vendors to present potential solutions to their current operational issues. These vendors included Application developers and Cloud-Q's solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.

A resource facing web interface that enables resources to apply and manage their assigned jobs.

An online payment facility for customers to pay for services.

Considering that LeadOps will host/process personal information on behalf of Clean-Q remotely, what is an appropriate next step for Clean-Q senior management to assess LeadOps' appropriateness?

- (A). Nothing at this stage as the Managing Director has made a decision.
- (B). Determine if any Clean-Q competitors currently use LeadOps as a solution.
- (C). Obtain a legal opinion from an external law firm on contracts management.
- (D). Involve the Information Security team to understand in more detail the types of services and solutions LeadOps is proposing.

Answer: D

NO.115 SCENARIO

Wesley Energy has finally made its move, acquiring the venerable oil and gas exploration firm Lancelot from its long-time owner David Wilson. As a member of the transition team, you have come to realize that Wilson's quirky nature affected even Lancelot's data practices, which are maddeningly inconsistent. "The old man hired and fired IT people like he was changing his necktie," one of Wilson's seasoned lieutenants tells you, as you identify the traces of initiatives left half complete. For instance, while some proprietary data and personal information on clients and employees is encrypted, other sensitive information, including health information from surveillance testing of employees for toxic exposures, remains unencrypted, particularly when included within longer records with less-sensitive data. You also find that data is scattered across applications, servers and facilities in a manner that at first glance seems almost random.

Among your preliminary findings of the condition of data at Lancelot are the following:

Cloud technology is supplied by vendors around the world, including firms that you have not heard of. You are told by a former Lancelot employee that these vendors operate with divergent security requirements and protocols.

The company's proprietary recovery process for shale oil is stored on servers among a variety of less-sensitive information that can be accessed not only by scientists, but by personnel of all types at most company locations.

DES is the strongest encryption algorithm currently used for any file.

Several company facilities lack physical security controls, beyond visitor check-in, which familiar vendors often bypass.

Fixing all of this will take work, but first you need to grasp the scope of the mess and formulate a plan

of action to address it.

Which procedure should be employed to identify the types and locations of data held by Wesley Energy?

- (A). Privacy audit.
- (B). Log collection
- (C). Data inventory.
- (D). Data classification.

Answer: C

NO.116 Granting data subjects the right to have data corrected, amended, or deleted describes?

- (A). Use limitation.
- (B). Accountability.
- (C). A security safeguard
- (D). Individual participation

Answer: D

NO.117 Which of the following does NOT illustrate the 'respect to user privacy' principle?

- (A). Implementing privacy elements within the user interface that facilitate the use of technology by any visually-challenged users.
- (B). Enabling Data Subject Access Request (DSARs) that provide rights for correction, deletion, amendment and rectification of personal information.
- (C). Developing a consent management self-service portal that enables the data subjects to review the details of consent provided to an organization.
- (D). Filing breach notification paperwork with data protection authorities which detail the impact to data subjects.

Answer: D

NO.118 SCENARIO

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis. LBH also implements Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are

not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent. What is the best way to ensure that the application only collects personal data that is needed to fulfill its primary purpose of providing potential medical and healthcare recommendations?

- (A). Obtain consent before using personal health information for data analytics purposes.
- (B). Provide the user with an option to select which personal data the application may collect.
- (C). Disclose what personal data the application the collecting in the company Privacy Policy posted online.
- (D). Document each personal category collected by the app and ensure it maps to an app function or feature.

Answer: C

NO.119 SCENARIO

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file. Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine. After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

How can Finley Motors reduce the risk associated with transferring Chuck's personal information to AMP Payment Resources?

- (A). By providing only the minimum necessary data to process the violation notice and masking all other information prior to transfer.
- (B). By requesting AMP Payment Resources delete unnecessary datasets and only utilize what is necessary to process the violation notice.
- (C). By obfuscating the minimum necessary data to process the violation notice and require AMP Payment Resources to secure store the personal information.
- (D). By transferring all information to separate datafiles and requiring AMP Payment Resources to combine the datasets during processing of the violation notice.

Answer: A

NO.120 What is the best way to protect privacy on a geographic information system (GIS)?

- (A). Limiting the data provided to the system.
- (B). Using a wireless encryption protocol.
- (C). Scrambling location information.
- (D). Using a firewall.

Answer: A

NO.121 Which of the following is NOT a workplace surveillance best practice?

- (A). Check local privacy laws before putting surveillance in place.
- (B). Ensure surveillance is discreet so employees do not alter their behavior.
- (C). Once surveillance data has been gathered, limit exposure of the content.
- (D). Ensure the minimal amount of surveillance is performed to meet the objective.

Answer: B

NO.122 What is true of providers of wireless technology?

- (A). They have the legal right in most countries to control and use any data on their systems.
- (B). They can see all unencrypted data that crosses the system.
- (C). They are typically exempt from data security regulations.
- (D). They routinely backup data that crosses their system.

Answer: B

NO.123 In day to day interactions with technology, consumers are presented with privacy choices. Which of the following best represents the Privacy by Design (PbD) methodology of letting the user choose a non-zero-sum choice?

- (A). Using images, words, and contexts to elicit positive feelings that result in proactive behavior, thus eliminating negativity and biases.
- (B). Providing plain-language design choices that elicit privacy-related responses, helping users avoid errors and minimize the negative consequences of errors when they do occur.
- (C). Displaying the percentage of users that chose a particular option, thus enabling the user to choose the most preferred option.
- (D). Using contexts, antecedent events, and other priming concepts to assist the user in making a better privacy choice.

Answer: B

NO.124 SCENARIO

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the Berry Country Regional Medical Center in Thorn Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You also recall a recent visit to the Records Storage Section, often termed "The Dungeon" in the basement of the old hospital next to the modern facility, where you noticed a multitude of paper records. Some of these were in crates marked by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. The back shelves of the section housed data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the dungeon, you noticed just ahead of you a small man in a lab coat who you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

Which cryptographic standard would be most appropriate for protecting patient credit card information in the records system?

- (A). Asymmetric Encryption
- (B). Symmetric Encryption
- (C). Obfuscation
- (D). Hashing

Answer: A

NO.125 What is a mistake organizations make when establishing privacy settings during the development of applications?

- (A). Providing a user with too many choices.
- (B). Failing to use "Do Not Track" technology.
- (C). Providing a user with too much third-party information.
- (D). Failing to get explicit consent from a user on the use of cookies.

Answer: D

NO.126 When releasing aggregates, what must be performed to magnitude data to ensure privacy?

- (A). Value swapping.
- (B). Noise addition.
- (C). Basic rounding.
- (D). Top coding.

Answer: B

NO.127 A privacy engineer has been asked to review an online account login page. He finds there is no limitation on the number of invalid login attempts a user can make when logging into their online account.

What would be the best recommendation to minimize the potential privacy risk from this weakness?

- (A). Implement a CAPTCHA system.
- (B). Develop server-side input validation checks.
- (C). Enforce strong password and account credentials.
- (D). Implement strong Transport Layer Security (TLS) to ensure an encrypted link.

Answer: B

NO.128 Which of the following is an example of drone "swarming"?

- (A). A drone filming a cyclist from above as he rides.
- (B). A drone flying over a building site to gather data.
- (C). Drones delivering retailers' packages to private homes.
- (D). Drones communicating with each other to perform a search and rescue.

Answer: D

NO.129 Why is first-party web tracking very difficult to prevent?

- (A). The available tools to block tracking would break most sites' functionality.
- (B). Consumers enjoy the many benefits they receive from targeted advertising.
- (C). Regulatory frameworks are not concerned with web tracking.
- (D). Most browsers do not support automatic blocking.

Answer: D

NO.130 SCENARIO

Kyle is a new security compliance manager who will be responsible for coordinating and executing controls to ensure compliance with the company's information security policy and industry standards. Kyle is also new to the company, where collaboration is a core value. On his first day of new-hire orientation, Kyle's schedule included participating in meetings and observing work in the IT and compliance departments.

Kyle spent the morning in the IT department, where the CIO welcomed him and explained that her department was responsible for IT governance. The CIO and Kyle engaged in a conversation about the importance of identifying meaningful IT governance metrics. Following their conversation, the CIO introduced Kyle to Ted and Barney. Ted is implementing a plan to encrypt data at the transportation level of the organization's wireless network. Kyle would need to get up to speed on the project and suggest ways to monitor effectiveness once the implementation was complete. Barney explained that his short-term goals are to establish rules governing where data can be placed and to minimize the use of offline data storage.

Kyle spent the afternoon with Jill, a compliance specialist, and learned that she was exploring an initiative for a compliance program to follow self-regulatory privacy principles. Thanks to a recent internship, Kyle had some experience in this area and knew where Jill could find some support. Jill also shared results of the company's privacy risk assessment, noting that the secondary use of personal information was considered a high risk.

By the end of the day, Kyle was very excited about his new job and his new company. In fact, he learned about an open position for someone with strong qualifications and experience with access privileges, project standards board approval processes, and application-level obligations, and couldn't wait to recommend his friend Ben who would be perfect for the job.

Which of the following should Kyle recommend to Jill as the best source of support for her initiative?

- (A). Investors.
- (B). Regulators.
- (C). Industry groups.
- (D). Corporate researchers.

Answer: C

NO.131 Implementation of privacy controls for compliance with the requirements of the Children's Online Privacy Protection Act (COPPA) is necessary for all the following situations EXCEPT?

- (A). A virtual jigsaw puzzle game marketed for ages 5-9 displays pieces of the puzzle on a handheld screen. Once the child completes a certain level, it flashes a message about new themes released that day.
- (B). An interactive toy copies a child's behavior through gestures and kid-friendly sounds. It runs on battery power and automatically connects to a base station at home to charge itself.

- (C). A math tutoring service commissioned an advertisement on a bulletin board inside a charter school. The service makes it simple to reach out to tutors through a QR-code shaped like a cartoon character.
- (D). A note-taking application converts hard copies of kids' class notes into audio books in seconds. It does so by using the processing power of idle server farms.

Answer: A

NO.132 What logs should an application server retain in order to prevent phishing attacks while minimizing data retention?

- (A). Limited-retention, de-identified logs including only metadata.
- (B). Limited-retention, de-identified logs including the links clicked in messages as well as metadata.
- (C). Limited-retention logs including the identity of parties sending and receiving messages as well as metadata.
- (D). Limited-retention logs including the links clicked in messages, the identity of parties sending and receiving them, as well as metadata.

Answer: B

NO.133 What is typically NOT performed by sophisticated Access Management (AM) techniques?

- (A). Restricting access to data based on location.
- (B). Restricting access to data based on user role.
- (C). Preventing certain types of devices from accessing data.
- (D). Preventing data from being placed in unprotected storage.

Answer: B

NO.134 What is the distinguishing feature of asymmetric encryption?

- (A). It has a stronger key for encryption than for decryption.
- (B). It employs layered encryption using dissimilar methods.
- (C). It uses distinct keys for encryption and decryption.
- (D). It is designed to cross operating systems.

Answer: C

NO.135 SCENARIO

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis. LBH also implements Privacy by Design (PbD) into the

application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

Regarding the app, which action is an example of a decisional interference violation?

- (A). The app asks income level to determine the treatment of care.
- (B). The app sells aggregated data to an advertising company without prior consent.
- (C). The app has a pop-up ad requesting sign-up for a pharmaceutical company newsletter.
- (D). The app asks questions during account set-up to disclose family medical history that is not necessary for the treatment of the individual's symptoms.

Answer: D

NO.136 Users of a web-based email service have their accounts breached through compromised login credentials. Which possible consequences of the breach illustrate the two categories of Calo's Harm Dimensions?

- (A). Financial loss and blackmail.
- (B). Financial loss and solicitation.
- (C). Identity theft and embarrassment.
- (D). Identity theft and the leaking of information.

Answer: D

NO.137 What risk is mitigated when routing video traffic through a company's application servers, rather than sending the video traffic directly from one user to another?

- (A). The user is protected against phishing attacks.
- (B). The user's identity is protected from the other user.
- (C). The user's approximate physical location is hidden from the other user.
- (D). The user is assured that stronger authentication methods have been used.

Answer: B

NO.138 What must be used in conjunction with disk encryption?

- (A). A digital signature.
- (B). A strong password.
- (C). Increased CPU speed.
- (D). Export controls.

Answer: A

NO.139 Which is NOT a drawback to using a biometric recognition system?

- (A). It can require more maintenance and support.
- (B). It can be more expensive than other systems
- (C). It has limited compatibility across systems.
- (D). It is difficult for people to use.

Answer: A

NO.140 SCENARIO

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the Berry Country Regional Medical Center in Thorn Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You also recall a recent visit to the Records Storage Section, often termed "The Dungeon" in the basement of the old hospital next to the modern facility, where you noticed a multitude of paper records. Some of these were in crates marked by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. The back shelves of the section housed data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the dungeon, you noticed just ahead of you a small man in a lab coat who you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

Which data lifecycle phase needs the most attention at this Ontario medical center?

- (A). Retention
- (B). Disclosure
- (C). Collection
- (D). Use

Answer: A

NO.141 SCENARIO

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the Berry Country Regional Medical Center in Thorn Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You also recall a recent visit to the Records Storage Section, often termed "The Dungeon" in the basement of the old hospital next to the modern facility, where you noticed a multitude of paper records. Some of these were in crates marked by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. The back shelves of the section housed data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the dungeon, you noticed just ahead of you a small man in a lab coat

who you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

Which regulation most likely applies to the data stored by Berry Country Regional Medical Center?

- (A). Personal Information Protection and Electronic Documents Act
- (B). Health Insurance Portability and Accountability Act
- (C). The Health Records Act 2001
- (D). The European Union Directive 95/46/EC

Answer: A

NO.142 What is the main reason a company relies on implied consent instead of explicit consent from a user to process her data?

- (A). The implied consent model provides the user with more detailed data collection information.
- (B). To secure explicit consent, a user's website browsing would be significantly disrupted.
- (C). An explicit consent model is more expensive to implement.
- (D). Regulators prefer the implied consent model.

Answer: A

NO.143 Which is likely to reduce the types of access controls needed within an organization?

- (A). Decentralization of data.
- (B). Regular data inventories.
- (C). Standardization of technology.
- (D). Increased number of remote employees.

Answer: C

NO.144 SCENARIO

Kyle is a new security compliance manager who will be responsible for coordinating and executing controls to ensure compliance with the company's information security policy and industry standards. Kyle is also new to the company, where collaboration is a core value. On his first day of new-hire orientation, Kyle's schedule included participating in meetings and observing work in the IT and compliance departments.

Kyle spent the morning in the IT department, where the CIO welcomed him and explained that her department was responsible for IT governance. The CIO and Kyle engaged in a conversation about the importance of identifying meaningful IT governance metrics. Following their conversation, the CIO introduced Kyle to Ted and Barney. Ted is implementing a plan to encrypt data at the transportation level of the organization's wireless network. Kyle would need to get up to speed on the project and suggest ways to monitor effectiveness once the implementation was complete. Barney explained that his short-term goals are to establish rules governing where data can be placed and to minimize the use of offline data storage.

Kyle spent the afternoon with Jill, a compliance specialist, and learned that she was exploring an initiative for a compliance program to follow self-regulatory privacy principles. Thanks to a recent internship, Kyle had some experience in this area and knew where Jill could find some support. Jill also shared results of the company's privacy risk assessment, noting that the secondary use of personal information was considered a high risk.

By the end of the day, Kyle was very excited about his new job and his new company. In fact, he learned about an open position for someone with strong qualifications and experience with access privileges, project standards board approval processes, and application-level obligations, and couldn't

wait to recommend his friend Ben who would be perfect for the job.

Ted's implementation is most likely a response to what incident?

- (A). Encryption keys were previously unavailable to the organization's cloud storage host.
- (B). Signatureless advanced malware was detected at multiple points on the organization's networks.
- (C). Cyber criminals accessed proprietary data by running automated authentication attacks on the organization's network.
- (D). Confidential information discussed during a strategic teleconference was intercepted by the organization's top competitor.

Answer: A

NO.145 What Privacy by Design (PbD) element should include a de-identification or deletion plan?

- (A). Categorization.
- (B). Remediation.
- (C). Retention.
- (D). Security

Answer: C

NO.146 After downloading and loading a mobile app, the user is presented with an account registration page requesting the user to provide certain personal details. Two statements are also displayed on the same page along with a box for the user to check to indicate their confirmation: Statement 1 reads: "Please check this box to confirm you have read and accept the terms and conditions of the end user license agreement" and includes a hyperlink to the terms and conditions. Statement 2 reads: "Please check this box to confirm you have read and understood the privacy notice" and includes a hyperlink to the privacy notice.

Under the General Data Protection Regulation (GDPR), what lawful basis would you primarily expect the privacy notice to refer to?

- (A). Consent.
- (B). Vital interests.
- (C). Legal obligation.
- (D). Legitimate interests.

Answer: A

NO.147 SCENARIO

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clean-Q invited vendors to present potential solutions to their current operational issues. These vendors included Application developers and Cloud-Q's solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.

A resource facing web interface that enables resources to apply and manage their assigned jobs.

An online payment facility for customers to pay for services.

If Clean-Q were to utilize LeadOps' services, what is a contract clause that may be included in the agreement entered into with LeadOps?

- (A). A provision that holds LeadOps liable for a data breach involving Clean-Q's information.
- (B). A provision prescribing technical and organizational controls that LeadOps must implement.
- (C). A provision that requires LeadOps to notify Clean-Q of any suspected breaches of information that involves customer or resource information managed on behalf of Clean-Q.
- (D). A provision that allows Clean-Q to conduct audits of LeadOps' information processing and information security environment, at LeadOps' cost and at any time that Clean-Q requires.

Answer: D

NO.148 A key principle of an effective privacy policy is that it should be?

- (A). Written in enough detail to cover the majority of likely scenarios.
- (B). Made general enough to maximize flexibility in its application.
- (C). Presented with external parties as the intended audience.
- (D). Designed primarily by the organization's lawyers.

Answer: C